UNIT 5 · TOPIC 5.4

Asymmetric Cryptography

Quiz, Answer Key

Teacher answer key, 18 questions, 1 point each. The correct answer is highlighted; the explanation and distractor notes follow.

1. A LightningGrid security engineer wants to send a confidential report to a colleague at another plant using PGP. Which key should the engineer use to encrypt the message?

- **● A. The recipient's public key**
- ○ B. The sender's own private key
- ○ C. The recipient's private key
- ○ D. The sender's own public key

Correct answer: A

Why: In asymmetric encryption, a message intended for a specific recipient is encrypted using that recipient's public key. Only the recipient's corresponding private key, never shared with anyone, can decrypt it, ensuring confidentiality.

*Why the others are wrong: **B**, Students often conflate encryption with digital signing; private keys are used to sign outgoing messages, not to encrypt messages for others. **C**, Private keys are never shared. If the recipient's private key were used, someone would have to transmit it, which defeats the entire security model. **D**, Encrypting with the sender's own public key would mean only the sender could decrypt, the recipient would have no way to read the message.*

2. A LightningGrid engineer digitally signs a classified message before transmitting it. Which key is used to create the digital signature?

- ○ A. The recipient's public key
- ○ B. The recipient's private key
- ○ C. The sender's own public key
- **● D. The sender's own private key**

Correct answer: D

Why: Digital signatures are created using the sender's private key. The recipient verifies the signature using the sender's public key, confirming both authenticity (the message came from the claimed sender) and non-repudiation (the sender cannot later deny sending it).

*Why the others are wrong: **A**, The recipient's public key is used to encrypt messages for the recipient, not to sign outgoing messages. **B**, The recipient's private key is not accessible to the sender; using it would require the recipient to share their private key, which violates key security. **C**, Public keys are freely distributed and known to all parties; signing with one's own public key would allow anyone to forge a signature since the key is public.*

3. A LightningGrid security team is selecting between 1024-bit and 3072-bit RSA keys for protecting inter-plant communications. Which statement best describes the effect of choosing the longer key?

- **● A. A 3072-bit key is computationally more difficult to factor, providing stronger security.**

○ B. Both key lengths provide equivalent protection against modern factoring attacks.

○ C. A 3072-bit key encrypts bulk data faster than a 1024-bit key.

○ D. A 1024-bit key is preferred because asymmetric algorithms do not benefit from longer key lengths.

Correct answer: A

Why: RSA security depends on the hardness of factoring large semiprime numbers. Longer keys increase the size of that number exponentially, making factoring vastly more difficult. 1024-bit RSA is now considered insufficient against modern factoring attacks; 3072-bit is a current recommended minimum for long-term security.

*Why the others are wrong: **B**, 1024-bit RSA has been deprecated by NIST precisely because it does not provide equivalent security to longer key sizes against modern adversaries. **C**, Longer asymmetric keys are generally slower for encryption operations, not faster, this is the opposite of the actual trade-off. **D**, Key length is directly tied to security strength for all asymmetric algorithms; this statement is factually incorrect.*

4. A LightningGrid colleague encrypts a sensitive report using PGP and sends it to a security engineer. The colleague confirms the message was encrypted with the receiving engineer's public key. Which key does the receiving engineer use to read the message?

○ A. The sender's public key

○ B. The sender's private key

● **C. Her own private key**

○ D. Her own public key

Correct answer: C

Why: Asymmetric encryption guarantees that only the intended recipient can decrypt a message. Since the message was encrypted with the recipient's public key, only the mathematically paired private key, held exclusively and privately by the recipient, can decrypt it. No other key, including the sender's, can perform this operation.

*Why the others are wrong: **A**, The sender's public key is used to verify signatures from the sender, not to decrypt messages encrypted for the recipient. **B**, The sender's private key is inaccessible to the recipient by design and is unrelated to decrypting a message encrypted with the recipient's public key. **D**, The recipient's own public key was used to encrypt; using it again to decrypt would be the same key in both directions, which is not how asymmetric systems work.*

5. LightningGrid receives a digital certificate from a third-party Certificate Authority (CA) to authenticate its public key. A security engineer needs to verify that the certificate is genuine and was not tampered with. Which key should the engineer use for verification?

○ A. LightningGrid's own private key

● **B. The CA's public key**

○ C. LightningGrid's own public key

○ D. The CA's private key

Correct answer: B

Why: A CA signs the certificate using its own private key. To verify the certificate's authenticity, the engineer uses the CA's public key, which is widely distributed as a

trusted root, to check the CA's signature on the certificate. This is how PKI establishes a chain of trust.

*Why the others are wrong: **A**, LightningGrid's private key is used for operations specific to LightningGrid (e.g., signing its own messages), not for verifying a CA's signature. **C**, LightningGrid's public key is what the certificate is attesting to, it cannot be used to verify the certificate that contains it. **D**, The CA's private key is never shared; it is used by the CA internally to sign certificates and must not be accessible to certificate holders or relying parties.*

6. NIST SP 800-131A deprecates 1024-bit RSA keys for federal use due to insufficient security strength. A LightningGrid engineer must select a replacement key length for a system that must remain secure through 2030. Which minimum RSA key length meets current NIST requirements for acceptable security strength over that period?

- ○ A. 512-bit
- ○ B. 1024-bit
- **● C. 2048-bit**
- ○ D. 1536-bit

Correct answer: C

Why: NIST SP 800-131A specifies that 2048-bit RSA keys provide 112-bit security strength, which is acceptable through at least 2030. 1024-bit RSA provides only 80-bit security strength and is disallowed for new applications. 512-bit is severely broken. 1536-bit is not a recognized transitional standard.

*Why the others are wrong: **A**, 512-bit RSA has been practically broken for decades and provides no meaningful security against modern adversaries. **B**, 1024-bit RSA is explicitly deprecated by NIST SP 800-131A and must not be used for new cryptographic operations. **D**, 1536-bit is not a recognized standard recommendation; NIST guidance skips from 1024-bit (deprecated) directly to 2048-bit (acceptable) in its transition guidance.*

7. LightningGrid's security architect proposes a layered communication architecture for inter-plant data transfer: asymmetric encryption handles the initial key exchange, and a symmetric session key handles bulk data encryption. Which statement best evaluates this design decision?

- ○ A. The design is flawed; asymmetric encryption is faster and should handle all data transfer directly.
- **● B. The design is sound; it uses asymmetric encryption's key-distribution guarantees for the handshake while delegating bulk encryption to the computationally efficient symmetric algorithm.**
- ○ C. The design fails because a symmetric key exchanged over an asymmetric channel cannot be trusted.
- ○ D. The design is unnecessary; modern symmetric ciphers alone can securely negotiate keys without asymmetric infrastructure.

Correct answer: B

Why: Hybrid cryptosystems, the basis of TLS, PGP, and most real-world secure communication protocols, use asymmetric encryption to securely establish a symmetric session key, then use that symmetric key for bulk data transfer. Asymmetric encryption is computationally expensive for large payloads but mathematically ideal for authenticated key exchange; symmetric encryption is efficient for bulk data but requires a secure key distribution mechanism, which asymmetric encryption provides.

*Why the others are wrong: **A**, Asymmetric encryption is substantially slower than symmetric encryption for bulk data, RSA operations on large plaintexts are computationally prohibitive in practice. **C**, Symmetric keys exchanged via asymmetric encryption inherit the security guarantees of the asymmetric channel. This is precisely the trusted path; the claim here is incorrect. **D**, Symmetric ciphers such as AES have no built-in mechanism for key agreement between parties who have never communicated; asymmetric cryptography solves this bootstrapping problem.*

8. A LightningGrid engineer must evaluate RSA key length recommendations for a PKI deployment protecting critical infrastructure data intended to remain confidential for 20 years. The engineer is aware that advances in quantum computing may threaten RSA within this timeframe. Which analysis best supports the key selection decision?

- ○ A. Select 2048-bit RSA; it is the current NIST minimum and no additional analysis is required.
- ○ B. Select 4096-bit RSA; longer classical keys provide indefinite future-proofing regardless of quantum computing advances.
- ○ C. Abandon asymmetric cryptography entirely and use only symmetric encryption.
- ● **D. Evaluate both current RSA key length standards and NIST post-quantum cryptography candidates, since classical key length alone does not protect against Shor's algorithm on a sufficiently powerful quantum computer.**

Correct answer: D

Why: RSA security rests on the computational hardness of integer factorization for classical computers. Shor's algorithm, running on a cryptographically relevant quantum computer, solves this problem in polynomial time regardless of classical key length. NIST's Post-Quantum Cryptography (PQC) standardization process addresses this threat with algorithms whose hardness assumptions survive quantum attack. A 20-year operational window requires evaluating PQC candidates alongside, or instead of, classical RSA options.

*Why the others are wrong: **A**, 2048-bit RSA meets current NIST standards for classical threat models, but does not address the quantum threat relevant to a 20-year deployment horizon. **B**, Shor's algorithm breaks RSA in polynomial time for any classical key length; increasing key size does not defeat a quantum adversary, only delays classical attacks. **C**, Symmetric encryption with sufficient key length (e.g., AES-256) is considered quantum-resistant under Grover's algorithm, but abandoning asymmetric cryptography entirely eliminates key exchange, digital signatures, and certificate infrastructure, not a practical solution.*

9. LightningGrid's PKI administrator discovers that the Certificate Authority (CA) that issued all company certificates has been compromised. An attacker may have used the CA's private key to issue fraudulent certificates. Which combination of mitigations best addresses this situation?

- ● **A. Revoke all certificates issued by the compromised CA via CRL and OCSP, remove the compromised CA from all trust stores, migrate to a new CA, and re-issue certificates only after re-verifying identities.**
- ○ B. Generate new RSA key pairs for all users and no further action; new keys are unaffected by the CA compromise.
- ○ C. Extend the validity period of existing certificates to give the CA time to recover without disrupting operations.

○ D. Distribute the compromised CA's public key to all users so they can individually identify fraudulent certificates.

Correct answer: A

Why: A CA compromise requires: (1) publishing revocations for all certificates in the compromised CA's chain via Certificate Revocation List (CRL) and Online Certificate Status Protocol (OCSP), so relying parties stop trusting them; (2) removing the compromised CA's root certificate from all trust stores; (3) migrating to a new, uncompromised CA; and (4) re-issuing certificates only after identity re-verification to prevent the attacker's fraudulent certificates from being re-legitimized. Generating only new user key pairs ignores fraudulent certificates already in circulation signed by the compromised CA.

*Why the others are wrong: **B**, New user key pairs address future key exposure but do not revoke fraudulent certificates the attacker may have already issued using the compromised CA key. **C**, Extending validity worsens the exposure window; compromised CA certificates must be revoked immediately, not kept alive longer. **D**, The compromised CA's public key is what users would use to verify the attacker's fraudulent certificates as valid, distributing it further increases exposure rather than reducing it.*

10. A LightningGrid security engineer is setting up PGP for the first time in order to exchange encrypted messages with a colleague. What is the correct first step?

○ A. Send a plaintext test message to the colleague to confirm connectivity.

● **B. Generate an asymmetric key pair.**

○ C. Request the colleague's private key.

○ D. Download and decrypt the colleague's encrypted message.

Correct answer: B

Why: Asymmetric encryption requires each party to first generate their own key pair consisting of a public key and a private key. The public key is then shared openly, while the private key is never transmitted. No encryption or signing operations are possible until each party has their own key pair.

*Why the others are wrong: **A**, Sending a plaintext message before establishing encrypted communication defeats the purpose of setting up PGP and exposes the channel before it is secured. **C**, Private keys must never be shared with anyone, including communication partners. Requesting a colleague's private key would compromise the entire asymmetric security model. **D**, No encrypted message from the colleague can exist yet, since neither party has exchanged public keys. This step comes much later in the process.*

11. After generating her PGP key pair, a LightningGrid engineer wants her colleague at another plant to be able to send her encrypted messages. What should she do next?

○ A. Send her private key to her colleague so he can encrypt messages for her.

○ B. Encrypt a test message using her own public key and send it to herself.

○ C. Ask her colleague to generate a key pair on her behalf.

● **D. Send her public key to her colleague.**

Correct answer: D

Why: Public keys are designed to be shared freely and widely. By sharing her public key with her colleague, the engineer allows him to encrypt messages that only she can decrypt using her private key. This is the fundamental mechanism of asymmetric key exchange.

*Why the others are wrong: **A**, The private key must never be shared with anyone. Sending it to a colleague gives them the ability to decrypt all messages intended for her and to impersonate her in signing operations. **B**, Self-encrypting a test message does not establish a secure channel with the colleague and does not give him the means to send her encrypted messages. **C**, Key pairs must be generated by the individual who will use them, so that the private key is never transmitted or held by a third party.*

12. A LightningGrid engineer receives a PGP-encrypted message from her colleague. Which key does she use to decrypt and read the message?

- **● A. Her own private key**
- ○ B. The colleague's private key
- ○ C. Her own public key
- ○ D. The colleague's public key

Correct answer: A

Why: PGP encrypts an outgoing message using the recipient's public key. The only key capable of decrypting it is the recipient's own private key, the mathematically paired counterpart that only the recipient holds. No other key, regardless of who possesses it, can perform this decryption.

*Why the others are wrong: **B**, The colleague's private key is inaccessible to the engineer and is used by the colleague for their own operations, not for decrypting messages directed to the engineer. **C**, The engineer's own public key was used by the colleague to encrypt the message; using it again to decrypt would be the same direction, which asymmetric algorithms do not support. **D**, The colleague's public key is used to verify the colleague's digital signatures, not to decrypt messages sent to the engineer.*

13. A LightningGrid engineer needs to send a classified document to a colleague. The document must satisfy both confidentiality (only the colleague can read it) and authenticity (the colleague can confirm it came from the engineer). Using PGP, which sequence of operations achieves both requirements?

- **● A. Sign the document with the sender's private key, then encrypt the signed document with the recipient's public key.**
- ○ B. Encrypt the document with the sender's private key, then sign it with the recipient's public key.
- ○ C. Encrypt the document with the sender's public key, then sign it with the recipient's private key.
- ○ D. Sign the document with the recipient's public key, then encrypt it with the sender's private key.

Correct answer: A

Why: Achieving both confidentiality and authenticity simultaneously requires two operations in a specific order: (1) sign with the sender's private key, this proves authorship, since only the sender holds that key; and (2) encrypt the signed document with the recipient's public key, this ensures only the recipient can decrypt and read it. This is the canonical PGP send sequence and the basis of authenticated encrypted messaging.

*Why the others are wrong: **B**, Encrypting with the sender's private key would allow anyone with the sender's public key (which is public) to decrypt the document, no confidentiality. Signing with the recipient's public key would allow anyone to forge that signature, no authenticity. **C**, The sender's public key is not used for encryption to the recipient; encrypting with it would allow only the sender to decrypt. The recipient's private key cannot be accessed by the sender. **D**, Public keys cannot be used to create valid signatures in standard*

asymmetric schemes; signing requires a private key. This option reverses the roles of both key types.

14. A LightningGrid engineer's laptop, which stores her PGP private key, is stolen. She has not yet shared a revocation certificate with anyone. What is the most appropriate immediate mitigation?

- ○ A. Generate a new key pair and silently replace her public key on the key server without notifying colleagues.
- ○ B. Continue using the old key pair until all in-flight encrypted messages are recovered and read.
- ○ C. Ask all colleagues to re-encrypt past messages they sent to her using her new key.
- ● **D. Publish a revocation certificate for the compromised key to the key server, notify all correspondents, and generate a new key pair with a new public key to distribute.**

Correct answer: D

Why: A compromised private key must be immediately revoked by publishing a revocation certificate to key servers, signalling to all parties that they should stop encrypting to that key. All correspondents must be explicitly notified since they may not routinely check revocation status. A new key pair is then generated and the new public key redistributed through a trusted channel. Silent replacement without revocation leaves the old key trusted by correspondents, enabling the attacker to decrypt intercepted future messages.

*Why the others are wrong: **A**, Silent replacement without revoking the old key leaves correspondents continuing to trust and encrypt to a compromised key, as they have no way to know it was replaced. **B**, Continuing to use a compromised key pair allows the attacker to decrypt any message encrypted to the stolen key and to forge the engineer's signature, neither is acceptable. **C**, Messages already encrypted and sent cannot be retroactively re-encrypted; the plaintext is not available to re-encrypt. Past confidentiality is permanently lost for messages encrypted to the compromised key.*

15. LightningGrid is evaluating an AI tool that automates PGP key pair generation and distributes public keys to all plants automatically. Which consideration is most critical when determining whether this tool is safe to deploy?

- ○ A. Whether the AI tool can generate key pairs faster than engineers doing so manually.
- ○ B. Whether the AI tool supports shorter key lengths to reduce processing overhead on older plant hardware.
- ○ C. Whether the AI tool has an intuitive interface that non-technical employees can use without training.
- ● **D. Whether the AI tool uses a cryptographically secure pseudorandom number generator (CSPRNG) for key generation and does not transmit or log private key material at any point.**

Correct answer: D

Why: The security of an asymmetric key pair depends entirely on two properties: the randomness of the key generation process, and the secrecy of the private key. A tool that uses a weak or predictable random source produces guessable keys; a tool that transmits or logs private keys creates a secondary attack surface that negates all cryptographic protections. These properties must be verified by examining the tool's documentation or

source code before deployment, regardless of convenience or speed advantages.

*Why the others are wrong: **A**, Generation speed is an operational concern, not a security concern. Cryptographic correctness must be established before operational efficiency is considered. **B**, Recommending shorter key lengths would reduce security below NIST minimums. This is a regression in security posture, not an acceptable performance trade-off. **C**, Usability is a secondary concern. A tool that is easy to use but mishandles private keys is more dangerous than a complex tool that handles them correctly.*

16. LightningGrid is deploying PGP across 200 plants. The security team must choose between a centralized key generation model, where IT generates all key pairs and distributes them, and a decentralized model, where each engineer generates their own key pair locally.

Which analysis best informs this architectural decision?

- ○ A. Centralized generation is always superior because it guarantees uniform key parameters and simplifies distribution logistics.
- ○ B. Decentralized generation is inherently insecure because engineers without cryptographic expertise will generate weak key pairs.
- ● **C. Decentralized generation eliminates the risk of a central administrator becoming a single point of compromise for all private keys; the trade-off is increased operational complexity in verifying that each engineer generated conformant key parameters.**
- ○ D. The choice between centralized and decentralized generation has no security implications; only the key length matters.

Correct answer: C

Why: A foundational principle of public-key cryptography is that private keys should be generated by and remain exclusively with their owner, and never transmitted. In a centralized model, the IT administrator holds all private keys at generation time, a single point of compromise affecting all 200 plants simultaneously. Decentralized generation ensures private keys never leave the owner's device, preserving this principle. The operational cost is a need for verified key generation tooling and parameter validation processes, which is manageable. This tension between administrative convenience and cryptographic principle is the same trade-off that distinguishes PGP's web-of-trust from hierarchical PKI.

*Why the others are wrong: **A**, Centralized generation's convenience comes with a catastrophic security trade-off: the central administrator temporarily possesses every private key, creating the single point of compromise that asymmetric cryptography is designed to avoid. **B**, Key generation tooling enforces parameter conformance regardless of the user's cryptographic expertise. The risk of weak parameters is mitigated by tooling, not by centralization, which introduces a more severe risk. **D**, Key generation architecture directly determines whether private keys are ever exposed to a third party. This is a more consequential security decision than key length selection.*

17. LightningGrid's CISO mandates that all cryptographic mitigations be logged for compliance with NERC CIP standards. A security engineer proposes the following logging scheme: (1) key generation events, key ID, algorithm, timestamp; (2) encryption and decryption events, message ID, key ID used, timestamp; (3) private key material, for audit purposes. Which evaluation of this proposal is most accurate?

- ○ A. The proposal is complete and should be implemented as described.

- ○ B. Item (1) is unnecessary overhead and should be removed; items (2) and (3) are appropriate for compliance.
- ○ C. Logging decryption events in item (2) constitutes an unauthorized interception of communications and should be removed to protect user privacy.
- ● **D. Logging private key material in item (3) fundamentally violates the security model of asymmetric cryptography; only operational metadata, key IDs, algorithm identifiers, timestamps, and operation types, should be logged.**

Correct answer: D

Why: Logging private key material creates a secondary, persistent attack surface: any party who gains access to the logs gains every private key ever generated, negating the mathematical protections of asymmetric cryptography entirely. NERC CIP compliance and general cryptographic audit practice require logging operational metadata, key identifiers (not values), timestamps, and operation types, to provide accountability without compromising key secrecy. Key generation events (item 1) are valuable audit data for detecting unauthorized key creation. Decryption event logs (item 2, minus key material) are legitimate for access auditing. Only item (3) is categorically incorrect.

*Why the others are wrong: **A**, Item (3) as written, logging private key material, is a critical security failure, not a compliant audit practice. **B**, Key generation event logs are valuable for detecting unauthorized key issuance and are required audit evidence in many compliance frameworks. They should not be removed. **C**, Logging that a decryption operation occurred, by whom, and using which key ID (without logging message contents or key material) is standard audit practice and does not constitute interception.*

18. LightningGrid is piloting an AI-assisted key management system that automatically detects anomalous private key usage, such as login from an unexpected geographic location, and triggers immediate key revocation. A senior engineer raises a concern that false positives could revoke the keys of engineers legitimately traveling between plants. Which response best balances security effectiveness with operational continuity?

- ○ A. Disable the AI system entirely to eliminate false positives and rely on manual revocation reporting.
- ○ B. Restrict all private key usage to a fixed geographic IP range per engineer to eliminate the anomaly detection problem entirely.
- ○ C. Accept all AI-triggered revocations without human review, since the cost of a missed true positive exceeds the cost of false positives.
- ● **D. Configure the AI system to require human confirmation before executing revocation, maintain rapid re-issuance procedures for false positives, and log all revocation decisions, AI-triggered and human-confirmed, for post-incident review and model refinement.**

Correct answer: D

Why: Effective AI-assisted security operations require human-in-the-loop oversight for irreversible, high-impact actions. Key revocation is irreversible in the sense that it immediately disrupts operations; false positives during inter-plant travel are both predictable and damaging. The appropriate design pattern is: (1) AI detects and flags the anomaly; (2) a human security analyst confirms before revocation executes; (3) rapid re-issuance procedures minimize operational downtime if a false positive does execute; (4) logging all decisions, including AI signals and human overrides, supports model improvement and post-incident analysis. This is the standard human-in-the-loop principle for AI-assisted mitigations involving irreversible or high-consequence actions.

*Why the others are wrong: **A**, Disabling anomaly detection eliminates a valuable automated mitigation capability. The solution to false positives is calibration and human oversight, not removal of the detection system. **B**, Fixed geographic IP restrictions would prevent legitimate mobility across 200 plants, creating an operational constraint that conflicts with the organization's distributed operational model and introduces a different class of vulnerability. **C**, Fully automated revocation without human confirmation for a system with known false positive risk will cause repeated operational disruptions and erode trust in the security tooling, an example of security controls undermining security posture.*